Guía2. Desarrollo Proyecto APT Asignatura Portafolio de Título

1. Resumen avance Proyecto APT

A continuación, encontrarás distintos campos que deberás completar con la información solicitada.

Resumen de avance proyecto APT	A la semana 9 del semestre (12 de octubre de 2026) el proyecto tiene completas y probadas las cuatro actividades que forman la base de red y protección perimetral (A1 a A4), además de la infraestructura del laboratorio sobre la que se construirán las etapas siguientes. Esto corresponde al cierre de la Etapa 1 de la metodología y a la mitad de la Etapa 2. Actividades realizadas y objetivos específicos cumplidos: • Infraestructura del laboratorio (actividad agregada, 22–23 de septiembre). Se desplegaron seis máquinas virtuales en Proxmox VE (Edge, pfSense, DMZ, VoIP, CORP-TEST y MGMT) sobre dos bridges aislados, y un borde público en AWS (EC2 Ubuntu con IP elástica) unido al laboratorio por un túnel WireGuard. El borde conserva la IP pública original del cliente al llegar a pfSense (prueba de preservación de origen: PASS). • A1 · Base pfSense y tuning Netmap — Objetivo específico 2 (parcial: optimización para Netmap). pfSense CE 2.9.0 instalado con interfaces WAN y trunk, offloading de hardware (checksum, TSO, LRO) desactivado y recursos de kernel ajustados. La auditoría automatizada con el perfil compatible con la versión actual obtuvo 14 PASS, 0 FAIL, y el script cuenta con 14 pruebas unitarias. • A2 · VLAN 802.1Q, DHCP y aislamiento — Objetivos específicos 1 y 2. Cuatro VLAN operativas (10 CORP, 20 DMZ, 30 VoIP, 99 MGMT) con DHCP propio y reglas de aislamiento. Se obtuvieron 16 comprobaciones PASS (8 de

<table>
<tr>
<td></td>
<td>DHCP, 5 accesos administrativos permitidos y 3 accesos inter-VLAN denegados), repetidas después de reiniciar el firewall.

• A3 · Suricata Inline IPS — Objetivo específico 3. Dos sensores Suricata en modo Inline/Netmap: uno en la WAN y otro en el trunk interno. Ambos descartan el tráfico marcado y registran el evento en eve.json (3 descartes nuevos por sensor), mientras el tráfico normal sigue funcionando (HTTP 200, ICMP 3/3). Se agregó un mecanismo de protección (readiness guard) que cierra el tráfico de datos si un sensor no está listo: el cierre se midió entre 0,6 y 1,2 s, y el arranque completo no dejó pasar tráfico sin inspección.

• A4 · Reputación y GeoIP con pfBlockerNG — Objetivo específico 4. MaxMind GeoLite2, Spamhaus DROP, FireHOL L1 y bloqueo por país (Rusia y Corea del Norte) aplicados en la WAN. Las cuatro reglas registraron exactamente +3 paquetes bloqueados en la prueba controlada.

• A9 · Acceso remoto Tailscale (adelantada, 60%). El equipo administra el laboratorio mediante una tailnet separada que entra solo por la VLAN de gestión, sin acceso al hipervisor.

• Bases para A5 y A7. DVWA y MariaDB ya corren en la VLAN DMZ (responden HTTP 200 internamente) y el contenedor de Asterisk está desplegado en la VLAN VoIP. Ninguna de estas dos actividades se declara completada por tener solo el servicio base.

La actividad A5 comienza esta semana según la Carta Gantt. A6 (motor de correlación), A8 (Gemini Live) y A10 (QA integral) aún no se inician, de acuerdo con sus ventanas planificadas. Los objetivos específicos 5 a 10 siguen pendientes.</td>
</tr>
<tr>
<td>Objetivos</td>
<td>El objetivo general se mantiene. Se ajustaron los siguientes objetivos específicos:
<table>
<tr><th>Objetivo</th><th>Formulación original</th><th>Ajuste y motivo</th></tr>
<tr><td>OE2 · pfSense</td><td>Implementar pfSense con políticas Zero Trust y optimización de hardware offloading para Netmap.</td><td>Se mantiene, pero se cambia el criterio de verificación. Tres parámetros del plan original ya no existen en pfSense 2.9.0 / FreeBSD 16. Se verifica con un perfil de auditoría compatible con la versión actual y no se cuentan como cumplidos parámetros inexistentes.</td></tr>
</table>
</td>
</tr>
</table>

	OE3 · Suricata	Configurar Suricata Inline IPS sobre Netmap con firmas ET Open y dropsid.conf.	Se amplía: además de la WAN, se inspecciona el trunk interno, porque un ataque SQLi dentro de HTTPS no es visible en la WAN. HAProxy terminará TLS y el sensor del trunk inspeccionará el HTTP en claro hacia la DMZ. Se agrega como requisito que el IPS no deje pasar tráfico sin inspeccionar durante el arranque o una caída (*fail-closed*).
	Nuevo OE (infraestructura)	—	Implementar un borde público (AWS EC2 + WireGuard) que exponga el laboratorio a Internet conservando la IP de origen real del atacante, sin depender de una IP pública fija ni de la red de la sede. Motivo: el CGNAT y las restricciones de puertos impedían exponer el laboratorio.
	OE9 / A9 · Tailscale	Malla Tailscale para softphones remotos de la subred VoIP.	Se amplía su uso: Tailscale también da acceso administrativo al equipo por la VLAN de gestión. El tráfico público no pasa por Tailscale; ese papel corresponde al túnel WireGuard con AWS.
Metodología	Se mantiene la metodología iterativa e incremental en 4 etapas, con estos ajustes: 1. Entorno de ejecución: en lugar de un laboratorio en un solo notebook, se trabaja en un servidor Proxmox VE on-premise con borde en AWS. Esto permite tener el laboratorio disponible 24/7 para los cuatro integrantes y hacer pruebas desde Internet real. 2. Clasificación de evidencias por estado: cada componente se reporta como *PROVISIONED* (recurso creado), *CONFIGURED* (configuración aplicada), *TESTED* (prueba ejecutada con resultado) o *VALIDATED* (criterios completos verificados). Tener una VM o un servicio activo no cuenta como actividad completada. 3. Pruebas con control positivo y negativo: cada prueba de bloqueo se acompaña de un control de tráfico legítimo antes y después, y solo se consideran eventos nuevos del ensayo, no registros anteriores.		

	4. Cambios protegidos con snapshots antes de cada modificación crítica (por ejemplo, pre-a3-trunk-20261002 y baseline-s7-20261002) y documentación de las fallas encontradas junto a su corrección.

Evidencia	Qué demuestra	Ubicación en el repositorio
E1 · Auditoría de kernel A1	Base de pfSense apta para Netmap: 14 PASS / 0 FAIL en pfSense CE 2.9.0 real.	evidencias/2026-10-02/pruebas/ampliacion-A1-kernel-netmap .png y src/pfsense_setup/
E2 · VLAN y DHCP A2	Segmentación 802.1Q y aislamiento: 16 PASS después del reinicio.	configuraciones/03-vlan-8021q.png y pruebas/ampliacion-A2-dhcp-segmentacion.png
E3 · Descarte IPS A3	Suricata descarta en la WAN y en el trunk, con eventos EVE nuevos, y el tráfico normal continúa.	configuraciones/09-suricata-interfaces.png y pruebas/ampliacion-A3-ips-wan-interno.png
E4 · Guard de arranque y fallos A3	Cierre *fail-closed* ante caída de sensores (0,6–1,2 s) y arranque sin tráfico sin inspeccionar (0 marcadores escapados).	pruebas/ampliacion-A3-guard-fallos-reinicio.png
E5 · Reputación y GeoIP A4	Spamhaus, RU, KP y FireHOL bloquean (+3 paquetes por regla).	pruebas/ampliacion-A4-reputacion-geoip.png
E6 · Borde público	La IP pública original del cliente llega intacta a pfSense a través de AWS y WireGuard.	pruebas/ampliacion-Transporte-ip-original.png y docs/AWS_WIREGUARD_EDGE.md
E7 · DVWA en DMZ (base de A5)	Aplicación vulnerable desplegada en la VLAN 20 y respondiendo internamente.	configuraciones/11-DVWA-login.png
Informe técnico S7 y presentación	Detalle de todas las pruebas, fallas y correcciones con fecha y hora.	docs/Fase_2_Desarrollo_Proyecto_APT/AVANCE_SEMANA7_2026-10-02.md y Evaluacion2_Avance_S7_Equipo_5_Slides_2026-10-02.pdf

Cómo dan cuenta del desarrollo del proyecto:

las evidencias no son solo capturas de configuración; muestran resultados medidos (contadores, eventos EVE, códigos HTTP y tiempos de cierre) con fecha y hora, comparando el resultado esperado con el obtenido. Esto responde al criterio indicado por el docente en las consultas de la Fase 2, que exige evidencia a nivel de sistema operativo y no solo capturas de la WebGUI.

Resguardo de la calidad según la disciplina:

• **Buenas prácticas de redes y seguridad:** segmentación 802.1Q con política de denegación por defecto entre VLAN, gestión fuera de banda por la VLAN 99, firmas oficiales ET Open sin desactivar reglas para ocultar advertencias y listas de reputación reconocidas (Spamhaus, FireHOL) con supresión de rangos privados RFC 1918 para evitar falsos bloqueos.

• **Verificación reproducible:** scripts de auditoría versionados en Git, 14 pruebas unitarias del verificador de kernel, 22 casos de prueba del verificador de estado del IPS y un manifest.json con el SHA-256 de cada imagen de evidencia.

• **Honestidad técnica:** se registran también los ensayos fallidos (por ejemplo, 70 s de arranque sin inspección y los ensayos de arranque 1, 3 y 5) y su corrección; los parámetros no soportados no se cuentan como cumplidos.

• **Seguridad de la información del propio proyecto:** no hay contraseñas, claves privadas ni licencias en el repositorio, los campos sensibles se ocultan en las capturas y el equipo no tiene acceso al hipervisor ni a la red de producción.

2. Monitoreo del Plan de Trabajo

Examina cuidadosamente tu plan de trabajo, enfocándote especialmente en la columna de estado de avance y ajustes.

Competencia o unidades de competencias	Actividades	Recursos	Duración de la actividad	Responsable	Observaciones	Estado de avance	Ajustes
Comp. 4 y 8	A0. Infraestructura del laboratorio: Proxmox VE (6 VMs, bridges aislados) y borde público AWS + WireGuard	Servidor Proxmox VE 9, AWS EC2 t3.micro con IP elástica, WireGuard, plantilla Ubuntu 24.04	22–23 sept. (S6)	[Completar: operador de infraestructura]	Facilitador: servidor con recursos suficientes (72 hilos, 131 GiB libres). Dificultad: CGNAT sin IP pública; se resolvió con la IP elástica de AWS.	Completado. Túnel, salida a Internet y preservación de la IP de origen probados (PASS).	Actividad nueva, no estaba en el plan de la Fase 1. Reemplaza el laboratorio en un solo notebook.
Comp. 4 y 8	A1. Diseño y setup base pfSense y tuning Netmap	Proxmox VE, ISO pfSense CE 2.9.0, scripts verify_kernel_hardening.py y kernel_netmap_tuning.sh	S1–S2 (17–30 ago.)	Bruno Urrea / Freddy Vásquez	Facilitador: documentación de Netgate. Dificultad: tres parámetros de kernel del plan no existen en FreeBSD 16 (resultado PARTIAL en la primera auditoría).	Completado / Ajustada. Perfil actual: 14 PASS, 0 FAIL (2 oct.).	Se reescribió la auditoría con el perfil current; el script y el XML ya no aplican parámetros inexistentes.

Comp. 4	A2. Segmentación de VLAN 802.1Q, DHCP y aislamiento	pfSense WebGUI, bridge VLAN-aware vmbr3, VMs de prueba por VLAN	S3–S4 (31 ago.–13 sept.)	Freddy Vásquez	Facilitador: soporte nativo de 802.1Q. Dificultad: la estructura de VLAN existía, pero faltaba demostrar DHCP y aislamiento en el entorno definitivo.	Completado (con retraso). 16 PASS el 1 y 2 de octubre, repetidos tras reiniciar.	Validación desplazada a S7. El aislamiento se probó con una muestra (TCP/22); la prueba exhaustiva de puertos pasa a A10.
Comp. 7 y 8	A3. Despliegue de Suricata Inline IPS	Paquete Suricata para pfSense, ET Open (26.628 reglas), Netmap, scripts del guard (infra/proxmox/)	S5–S6 (14–27 sept.)	Bruno Urrea / Kevin Retamales	Dificultades: al activar el sensor del trunk se cortó la conectividad de las VLAN (tagging VLAN por hardware); 70 s de arranque sin inspección; advertencia de dependencia flowbit.	Completado / Ajustada (2 oct.). Descarte en WAN y trunk PASS; guard PASS.	Se agregó el sensor del trunk y el readiness guard fail-closed. Validación desplazada a S7. El rendimiento bajo carga pasa a A10.
Comp. 7 y 8	A4. Hardening GeoIP y reputación con pfBlockerNG	pfBlockerNG-devel, cuenta MaxMind GeoLite2, Spamhaus DROP, FireHOL L1	S7–S8 (28 sept.–11 oct.)	Kevin Retamales	Dificultad: dependencia de credenciales MaxMind y FireHOL bloqueando rangos privados del laboratorio. Facilitador: listas públicas mantenidas.	Completado dentro de plazo. 4 reglas PASS (+3 paquetes c/u).	FireHOL con supresión de RFC 1918, CGNAT y loopback; capacidad de tablas PF en 2.000.000 de entradas.

Comp. 7	A5. Proxy inverso HAProxy HTTPS y DVWA en DMZ	Paquete HAProxy, CA interna, Docker, DVWA + MariaDB (VM102, VLAN 20)	S9–S10 (12–25 oct.)	Cristóbal Quezada	Facilitador: DVWA ya desplegada y el borde público ya publica TCP 80/443 hacia pfSense. Dificultad: certificados en laboratorio y coordinación con el sensor del trunk.	En curso (inicia en S9). DVWA responde HTTP 200 interno.	HAProxy terminará TLS para que el sensor del trunk inspeccione el HTTP en claro hacia la DMZ.
Comp. 6 y 8	A6. Motor de correlación KRONOS (Python, eve.json, pfctl)	Python 3.12, PyYAML, utilidades pfctl, prototipos en src/pfsense_ pfctl_engine/	S11–S12 (26 oct.–8 nov.)	Bruno Urrea	Dificultad prevista: privilegios para manipular tablas del kernel; se usará sudoers restringido.	No iniciado (según calendario). Existe un prototipo de código sin pruebas.	Sin ajuste de plazo. Deberá convivir con el guard del IPS sin vaciar estados de forma global.
Comp. 5	A7. Centralita Asterisk 20 LTS PBX y AMI	Docker, Asterisk 20, PJSIP, AMI, softphone (VM103, VLAN 30)	S13–S14 (9–22 nov.)	Freddy Vásquez	Facilitador: contenedor ya activo escuchando UDP 5060. Dificultad prevista: NAT traversal de SIP y RTP.	En curso (adelantado): host y contenedor provisionados; AMI y llamadas pendientes.	Provisión adelantada; el resto se mantiene en su ventana.
Comp. 3 y 5	A8. Integración Gemini Live Voice	Google AI Studio (API key), Python websockets, puente de audio PCM 24 kHz	S14–S15 (16–29 nov.)	Bruno Urrea	Dificultad prevista: sincronización del audio RTP con WebSocket.	No iniciado (según calendario).	Sin ajuste.

Comp. 3 y 4	A9. Acceso Zero Trust con Tailscale (administración y softphones)	Tailscale (tailnet separada del equipo), subnet router KRONOS-MGMT	S15 (23–29 nov.)	Freddy Vásquez	Facilitador: WireGuard atraviesa el CGNAT. Dificultad: falta probar la autenticación desde el dispositivo de cada compañero.	Ajustada / En curso (adelantada, aprox. 60%).	La parte de administración del equipo se adelantó a S6; los softphones y las ACL quedan en S15.
Comp. 7, 8 y 11	A10. Pruebas QA integrales, auditoría y defensa	Repositorio GitHub, DVWA, softphone, guiones de ataque SQLi, manuales PDF	S16–S18 (30 nov.–20 dic.)	Todo el equipo (Kevin Retamales como referente de QA)	Facilitador: ya existen evidencias parciales y procedimientos de prueba. Dificultad prevista: conectividad durante la defensa presencial.	No iniciado (según calendario).	Se agregan pendientes heredados: prueba exhaustiva de puertos, rendimiento de Suricata y rotación de logs bajo carga.

3. Ajustes a partir del monitoreo

Profundiza en las observaciones de tu plan de trabajo. Analiza las actividades planificadas y señala qué aspectos facilitaron u obstaculizaron la ejecución del plan. Plantea cómo abordaste y/o abordarás los obstáculos. Por último, señala los ajustes que realizaste al plan de trabajo a partir de este análisis.

Factores que han facilitado y/o dificultado el desarrollo de mi plan de trabajo:

Factores que facilitaron:

• **Infraestructura propia disponible:** contar con un servidor Proxmox con recursos suficientes permitió montar un laboratorio de seis VMs que se aproxima a una red corporativa real y que está disponible para todo el equipo en cualquier momento.

• **Herramientas 100% open source y capas gratuitas** (pfSense, Suricata, pfBlockerNG, Tailscale, MaxMind GeoLite2), lo que mantuvo el costo de licencias en $0. El único recurso de nube es una instancia t3.micro de AWS.

• **Automatización y control de versiones:** los scripts de auditoría, los snapshots y el repositorio Git permitieron repetir las pruebas después de cada cambio y recuperar el sistema ante fallas sin perder trabajo.

• **Roles bien definidos** desde la Fase 1, lo que deja claro quién responde por cada componente.

Factores que dificultaron y acciones tomadas:

Dificultad	Acción tomada o por tomar
Sin IP pública: CGNAT del proveedor y bloqueo de puertos en la red de la sede.	Borde en AWS con IP elástica y túnel WireGuard hacia el laboratorio, conservando la IP de origen del atacante (probado).
Parámetros de kernel del plan original que no existen en pfSense 2.9.0 / FreeBSD 16.	Revisión de las fuentes oficiales y nuevo perfil de auditoría para la versión actual (14/14 PASS); los parámetros retirados se informan como diagnóstico aparte.
Al activar Suricata en el trunk se cortó la conectividad de todas las VLAN.	Recuperación por consola de la VM, desactivación del tagging y filtrado VLAN por hardware en vtnet1 y comando persistente al arranque. Se documentó el procedimiento seguro para cambios futuros.

Actividades ajustadas o eliminadas:

No se eliminó ninguna actividad. Se realizaron los siguientes ajustes:

• **Nueva actividad A0 (infraestructura Proxmox + borde AWS):** fue necesaria para resolver la exposición pública y dar al equipo un laboratorio compartido. Sin ella, las pruebas de ataque desde Internet de A5 y A10 no serían posibles.

• **A1, cambio en el criterio de verificación:** se reemplazaron los parámetros obsoletos por los de la versión actual de FreeBSD, para no declarar como cumplido algo que el sistema ya no soporta.

• **A3, ampliación del alcance:** se agregó un segundo sensor en el trunk interno, porque el SQLi viajará cifrado por HTTPS y solo será visible después de que HAProxy termine TLS. También se agregó el guard fail-closed para que no haya ventanas sin protección.

• **A4, ajuste de configuración:** FireHOL con supresión de redes privadas y aumento de la capacidad de tablas PF.

• **A9, adelanto parcial:** el acceso administrativo por Tailscale se implementó en S6 porque el equipo lo necesitaba para trabajar en el laboratorio; la parte de softphones se mantiene en S15.

• **A5 (mi actividad):** se mantiene en su plazo (S9–S10), pero se incorpora como requisito explícito que el tráfico HTTP descifrado hacia la DMZ pase por el sensor del trunk. Así A5 conecta directamente con la detección de SQLi de A6.

Actividades que no has iniciado o están retrasadas:

• **A2 y A3 (retrasadas, ya recuperadas):** se validaron en la semana 7 en lugar de S4 y S6. El motivo fue el cambio de entorno a Proxmox + AWS en la semana 6, que obligó a volver a configurar y probar en el entorno definitivo, y las fallas técnicas descritas (corte de VLAN y ventana de arranque). La estrategia fue concentrar el trabajo en S7, repetir todas las pruebas después de reiniciar y documentar cada falla con su corrección. Ambas actividades están completadas y no afectaron el plazo de A4, que se cerró dentro de su ventana.

• **A5 (en curso desde S9):** no está retrasada. Para cumplir el plazo del 25 de octubre se trabajará en este orden: (1) CA interna y certificado del laboratorio; (2) frontend HTTPS 443 con terminación TLS y backend hacia DVWA (192.168.20.50:80); (3) stick-tables de límite de tasa; (4) prueba de extremo a extremo desde Internet por el borde AWS, con control HTTP 200 y verificación de que el sensor del trunk genera eventos EVE. Se tomará un snapshot antes de cada cambio en pfSense.

• **A6, A8 y A10 (no iniciadas, según calendario):** no presentan retraso porque sus ventanas comienzan en S11, S14 y S16. El riesgo principal es la dependencia en cadena (A5 → A6 → A7/A8 → A10). Por eso se adelantaron la provisión de Asterisk (A7) y el acceso del equipo (A9), y se dejó un prototipo del motor KRONOS en el repositorio.

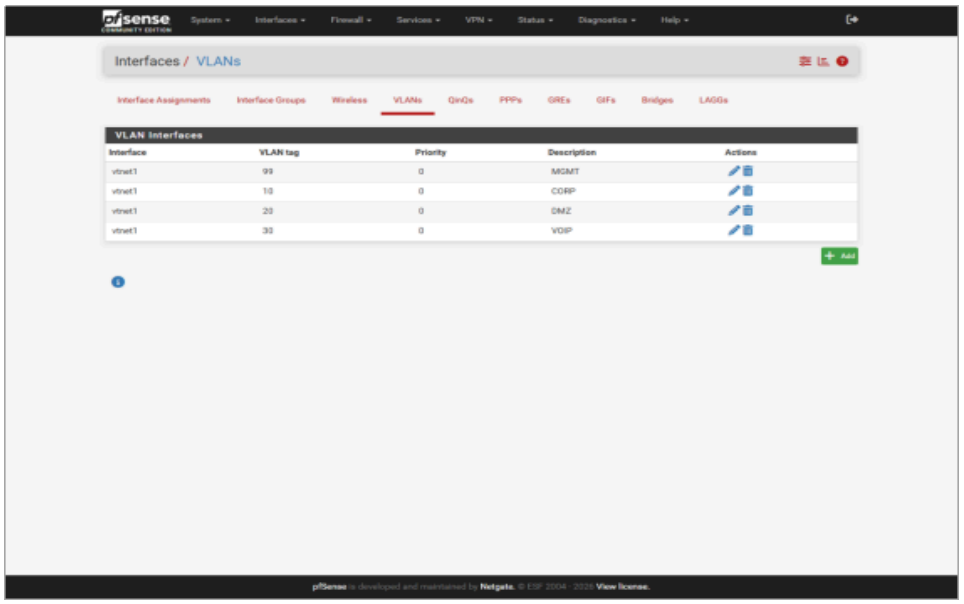
• **Pendientes heredados para A10:** prueba exhaustiva de aislamiento entre VLAN (todos los puertos), rendimiento de Suricata bajo carga, rotación de logs y medición de latencia total (<1,5 s). Quedarán incluidos en la matriz de QA.

Anexo A. Evidencias seleccionadas

Las imágenes de pruebas son transcripciones visuales de comandos ejecutados el 2 de octubre de 2026 (indicado en cada imagen). Las de configuración son capturas de la WebGUI de pfSense con los datos sensibles ocultos.



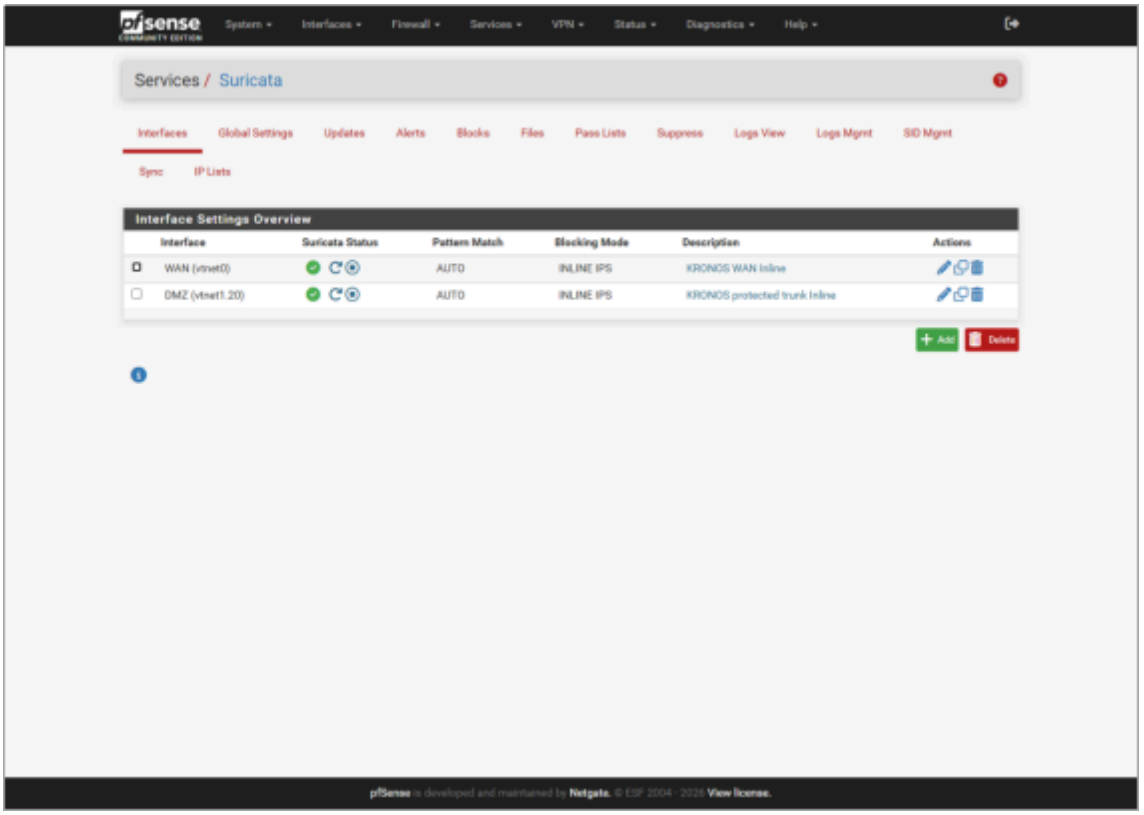
E1 · A1: auditoría de kernel y Netmap en pfSense CE 2.9.0 (14 PASS / 0 FAIL).



E2a · A2: VLAN 802.1Q configuradas sobre el trunk de pfSense.



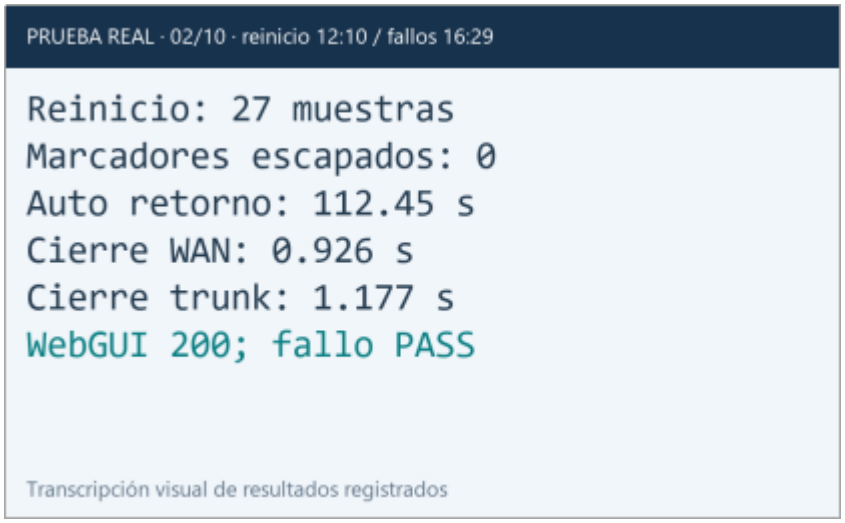
E2b · A2: DHCP en las cuatro VLAN, accesos administrativos y aislamiento (16 PASS).



E3a · A3: sensores Suricata Inline en WAN y trunk.



E3b · A3: descartes con eventos EVE nuevos en WAN y trunk; tráfico normal permitido.



E4 · A3: readiness guard ante caídas de sensores y reinicio completo.



E5 · A4: bloqueos Spamhaus, RU, KP y FireHOL (+3 paquetes por regla).



E6 · Borde AWS + WireGuard: preservación de la IP pública de origen.



E7 · Base de A5: DVWA desplegada en la VLAN 20 (DMZ).